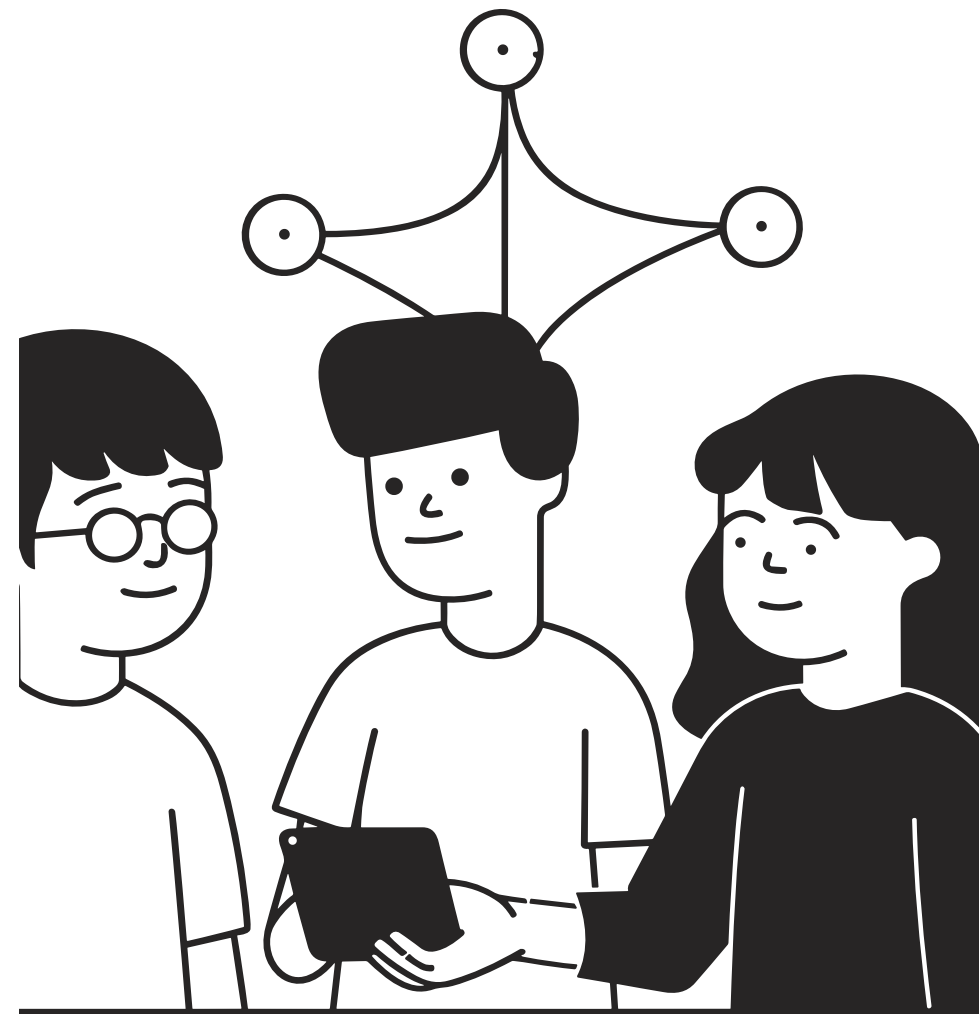


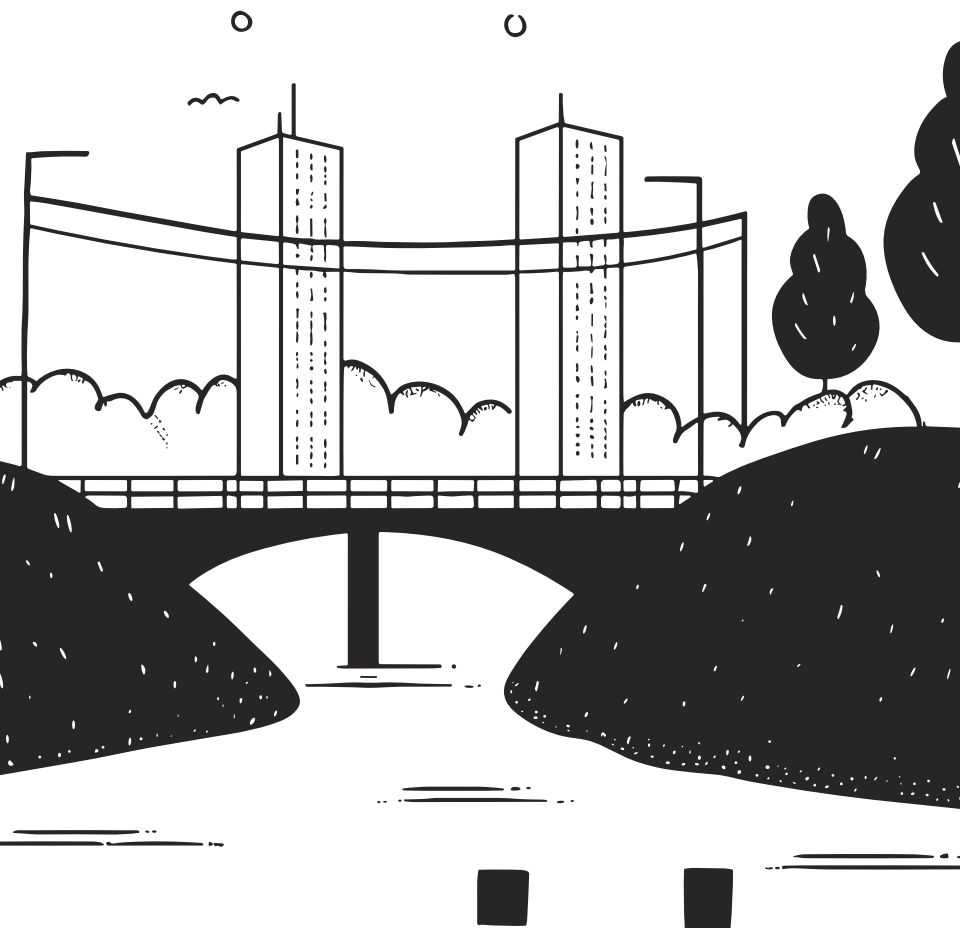
R2M6 — Mini API d'autenticació per a client

El backend ja no parla només amb el navegador: ara respon **JSON** a qualsevol client que sàpiga escoltar.

DWES · DWEC

RA4





Per què ara una mini API?

DWEC necessita backend

El mòdul de client necessita autenticar-se contra un servidor real, no simulat.

R4 queda lluny

L'API formal amb documentació i protecció completa arriba en R4. Ara fem el mínim funcional.

Un pont intermodular

R2M6 connecta el treball de DWES amb el que DWEC construirà sobre ell.

Què reutilitzem de R2M5

No partim de zero: tot el que ja funciona al backend es reutilitza directament.



Usuaris existents

La taula d'usuaris i el sistema de registre de R2M5 ja estan llestos.



Validació de contrasenya

El hash i la verificació amb `password_verify()` es mantenen intactes.



Operació protegida

La lògica d'accés restringit i les regles bàsiques d'autorització ja existeixen.

El contracte mínim

Client fa la petició

POST /api/login

Cos JSON amb
username i password.

GET /api/me

Header Authorization:
Bearer <token> per
identificar l'usuari
autenticat.

Servidor respon JSON

Token simple

Resposta amb un token
manejaable: no cal JWT
complet, n'hi ha prou
amb un identificador
segur.

Dades de l'usuari

Nom, rol o qualsevol
camp útil. **Mai** la
contrasenya ni el hash.

Respostes clares i predictibles

El client ha de poder interpretar sempre el resultat sense ambigüitats.

200 OK

Login correcte. Retorna el token i les dades bàsiques de l'usuari autenticat.

401 Unauthorized

Credencials incorrectes o token invàlid. Missatge d'error clar i interpretable.

Sense secrets

La resposta no inclou mai la contrasenya, el hash ni informació sensible interna.

Prova externa: com verificar que funciona



Eines de prova

→ curl

Prova ràpida des del terminal sense cap eina addicional.

→ Postman / Insomnia

Interfície visual per construir peticions i inspeccionar respostes JSON.

→ fetch des del client

La prova definitiva: un client JavaScript real consumint l'API.



Prova sempre el cas correcte i el cas incorrecte.

Què *no* és encara R2M6

Conèixer els límits d'aquest repte és tan important com saber el que s'implementa.

No és un CRUD complet

Ni OpenAPI, ni documentació formal de l'API.

No és OAuth

Ni JWT professional, ni refresh tokens, ni flux d'autorització delegada.

No té rols complexos

La gestió de permisos avançats queda fora d'abast per ara.

❏ L'objectiu és una porta mínima i estable, no una API de producció.

Pont cap a R4

R2M6 és el primer pas d'un camí que es completarà més endavant.

1

R2M5

Registre, hash, login, sessió i operació protegida al navegador.

2

R2M6 — Ara

Mini API mínima i consumible. Primera conversa JSON entre client i servidor.

3

R4

Contracte formal, documentació, protecció completa i API de producció.

R2M6 no és una API completa: és el **primer contracte d'autenticació** perquè el client puga parlar amb el backend.

